

ĐẠI HỌC BÁCH KHOA HÀ NỘI
TRƯỜNG CÔNG NGHỆ THÔNG TIN & TRUYỀN THÔNG



Báo Cáo Bài Tập Lớn

Đề tài: **Hạ Tầng Khóa Công Khai**
(Public Key Infrastructure – PKI)

Học phần: **Nhập môn An toàn thông tin – IT4015**

Mã học phần: IT4015

Mã lớp: 167834

Giảng viên:	PGS. TS. Nguyễn Linh Giang	
Nhóm sinh viên:	Đỗ Trường Giang	20235066
	Hoàng Minh Khôi	20230042
	Phạm Gia Hưng	20230036
	Nguyễn Thanh Tú	20230075

Hà Nội, June 8, 2026

Contents

1	Giới thiệu	1
1.1	Vấn đề đặt ra	1
1.2	Phạm vi và bố cục báo cáo	1
2	Nền tảng mật mã khóa công khai	2
2.1	Mật mã đối xứng và hạn chế	2
2.2	Mật mã khóa công khai	2
2.3	Tại sao mật mã bất đối xứng chưa đủ	2
3	Cấu trúc hạ tầng khóa công khai PKI	3
3.1	Các mô hình phân phối khóa công khai	3
3.1.1	Bài toán phân phối khóa công khai	3
3.1.2	Public Announcement	3
3.1.3	Host-based Trust	4
3.1.4	Web of Trust (PGP)	4
3.1.5	Hierarchical PKI	4
3.1.6	So sánh trade-off	4
3.2	Định nghĩa và mục tiêu PKI	5
3.3	Các thành phần PKI	6
3.4	Chu kỳ sống của chứng chỉ	8
4	Chứng chỉ số và các chuẩn	10
4.1	Chứng chỉ số X.509	10
4.2	Các trường X.509 v3	11
4.3	Distinguished Name	11
4.4	Extension quan trọng	12
4.5	Certificate Signing Request	13
4.6	Phân loại chứng chỉ	13
4.7	Các chuẩn PKCS	14
4.8	RFC và chuẩn quan trọng	14

5	Triển khai và ứng dụng thực tế	15
5.1	HTTPS / TLS	15
5.2	Chữ ký số văn bản	17
5.3	S/MIME	18
5.4	VPN và IPSec	18
5.5	Code Signing	19
5.6	eGovernment Việt Nam	20
6	Các hệ thống PKI mã nguồn mở	21
6.1	OpenSSL	21
6.2	EJBCA	21
6.3	Let's Encrypt và Certbot	21
6.4	Các công cụ và nền tảng khác	21
7	Thách thức và xu hướng	22
7.1	Thách thức hiện tại	22
7.2	Xu hướng mới	22
8	Kết luận	23
8.1	Tổng kết	23
8.2	Ý nghĩa và triển vọng	23
	Tài liệu tham khảo	24

List of Figures

3.1	Quy trình tạo và xác thực chữ ký số sử dụng cặp khóa công khai và bí mật.	6
3.2	Sơ đồ chu kỳ sống của chứng chỉ số trong hệ thống PKI	9
5.1	Mẫu kiểm tra PKI trong ứng dụng thực tế	16

List of Tables

3.1	So sánh các mô hình tin cậy (Trust Models)	5
3.2	So sánh các phương pháp kiểm tra trạng thái thu hồi chứng chỉ	7
4.1	Các trường chính trong chứng chỉ X.509 v3	11
4.2	Một số extension thường gặp trong X.509 v3	12
4.3	Phân loại chứng chỉ theo mục đích sử dụng	13
5.1	So sánh một số ứng dụng PKI	15

Chapter 1

Giới thiệu

1.1 Vấn đề đặt ra

1.2 Phạm vi và bố cục báo cáo

Chapter 2

Nền tảng mật mã khóa công khai

2.1 Mật mã đối xứng và hạn chế

Nguyên lý mật mã đối xứng

Bài toán phân phối khóa

Giải pháp KDC và giới hạn

2.2 Mật mã khóa công khai

Cặp khóa bất đối xứng và trapdoor function

Thuật toán RSA

Trao đổi khóa Diffie-Hellman

Sơ đồ chữ ký số

2.3 Tại sao mật mã bất đối xứng chưa đủ

MITM attack trên raw public key

Vấn đề ràng buộc danh tính

Chapter 3

Cấu trúc hạ tầng khóa công khai PKI

Hạ tầng khóa công khai (Public Key Infrastructure - PKI) thường bị nhầm tưởng chỉ là một tập hợp các thuật toán mã hóa và phần mềm. Tuy nhiên, trên thực tế, PKI là một hệ thống toàn diện, là sự tổ hợp chặt chẽ giữa con người, quy trình, phần mềm, phần cứng và các chính sách an toàn thông tin. Mục tiêu cốt lõi của hệ thống này là tạo ra, quản lý, phân phối, sử dụng, lưu trữ và thu hồi các chứng chỉ số một cách an toàn, từ đó thiết lập và duy trì nền tảng tin cậy cho các giao dịch điện tử trên môi trường mạng không an toàn.

3.1 Các mô hình phân phối khóa công khai

Sự phát triển của các cơ chế phân phối khóa công khai trải qua nhiều giai đoạn tiến hóa, từ các phương pháp thủ công, đơn giản như Host-based Trust, phân tán như Web of Trust, cho đến các mô hình có tính hệ thống cao như Hierarchical PKI. Mỗi mô hình ra đời nhằm giải quyết những hạn chế của mô hình trước đó, nhưng đồng thời cũng phải đối mặt với những thách thức mới.

3.1.1 Bài toán phân phối khóa công khai

Trong hệ mật mã bất đối xứng, khóa công khai (Public Key) được thiết kế để công bố rộng rãi cho bất kỳ ai muốn giao tiếp an toàn với chủ sở hữu của nó. Tuy nhiên, bài toán đặt ra là làm thế nào để phân phối khóa công khai này rộng rãi mà vẫn đảm bảo tính an toàn. Quá trình phân phối này cần hướng tới việc hỗ trợ bốn mục tiêu an toàn thông tin cơ bản: tính xác thực (Authentication), tính bảo mật (Confidentiality), tính toàn vẹn (Integrity) và tính chống chối bỏ (Non-repudiation).

3.1.2 Public Announcement

Đây là phương pháp cơ bản nhất, trong đó khóa công khai được chia sẻ công khai trên một nền tảng dễ tiếp cận. Một ví dụ tiêu biểu là DNSSEC, nơi khóa công khai được lưu

trữ trực tiếp trong các bản ghi DNS và bất kỳ ai cũng có thể truy vấn thông qua các công cụ như `dig`. Tuy nhiên, điểm yếu lớn nhất của phương pháp này nằm ở khả năng xác thực (Authentication). Khi nhận được một khóa công khai, người dùng không có cơ chế đáng tin cậy nào để kiểm chứng xem khóa đó có thực sự thuộc về thực thể mà nó tự nhận hay không, dẫn đến rủi ro cao về các cuộc tấn công trung gian (Man-in-the-Middle).

3.1.3 Host-based Trust

Mô hình này dựa trên việc thiết lập sự tin cậy thủ công giữa các thiết bị. Điển hình là cơ chế của SSH, sử dụng tệp `known_hosts` để mỗi máy tính tự lưu trữ và quản lý danh sách các khóa công khai mà nó cho là an toàn. Mặc dù hiệu quả trong các hệ thống nhỏ, nhưng khi số lượng thiết bị tăng lên, số lượng kết nối tin cậy cần thiết lập sẽ tăng theo cấp số nhân ($O(n^2)$ cho n máy tính). Điều này khiến mô hình Host-based Trust hoàn toàn thiếu khả năng mở rộng (scalability) và không thể áp dụng cho mạng Internet toàn cầu.

3.1.4 Web of Trust (PGP)

Để khắc phục tính tập trung, Web of Trust (WoT) được giới thiệu trong các hệ thống như PGP (Pretty Good Privacy) [1]. Đây là một mô hình phi tập trung, dựa trên sự xác nhận lẫn nhau (peer endorsement) giữa các người dùng; mỗi cá nhân tự chịu trách nhiệm quyết định mức độ tin cậy đối với khóa của người khác dựa trên các chữ ký xác nhận của bạn bè hoặc đối tác. Dù rất dân chủ và phù hợp cho các cộng đồng kỹ thuật nhỏ, WoT gặp phải vấn đề lớn về "bootstrapping" (khó khăn cho người mới tham gia để có được sự tin cậy) và tính thân thiện với người dùng thông thường, do đó không thể mở rộng ở quy mô toàn cầu.

3.1.5 Hierarchical PKI

Đây là mô hình phổ biến và thành công nhất hiện nay trên Internet. Hierarchical PKI sử dụng cấu trúc cây phân cấp dựa trên nguyên tắc "tin cậy bắc cầu" (transitive trust). Sự tin cậy được kế thừa từ các Root CA (Tổ chức phát hành chứng chỉ gốc) trên cùng, truyền xuống các Intermediate CA, và cuối cùng đến các chứng chỉ thực thể (Leaf certificates). Ở phía máy khách, hệ điều hành và trình duyệt (như Mozilla NSS, Microsoft, Apple) duy trì một kho lưu trữ chứng chỉ gốc đáng tin cậy (Trust Store). Hoạt động của các CA này được quản lý và tiêu chuẩn hóa thông qua các yêu cầu cơ sở (baseline requirements) do CA/Browser Forum [2] ban hành.

3.1.6 So sánh trade-off

Sự khác biệt giữa các mô hình chủ yếu nằm ở cách tiếp cận quản lý sự tin cậy. Mô hình phân cấp (Hierarchical) có ưu điểm là dễ dàng kiểm toán (audit) và thu hồi chứng chỉ

(revoke), quản lý thống nhất, nhưng lại biến các Root CA thành những điểm yếu chí mạng (Single Point of Failure - SPOF) về mặt tin cậy. Ngược lại, mô hình phi tập trung như Web of Trust không có SPOF, nhưng quá trình đánh giá niềm tin lại không đủ tính bắc cầu mạnh mẽ và quá phức tạp đối với người dùng phổ thông.

Table 3.1: So sánh các mô hình tin cậy (Trust Models)

Tiêu chí	Hierarchical PKI (Centralized)	Web of Trust (Decentralized)
Cấu trúc	Cây phân cấp từ Root CA xuống Leaf	Mạng lưới đồng đẳng (Peer-to-peer)
Quản lý thu hồi	Dễ dàng, quản lý tập trung (CRL/OCSP)	Khó khăn, phụ thuộc vào bản cập nhật của từng node
Rủi ro (SPOF)	Root CA bị xâm nhập là thảm họa	Không có SPOF rõ rệt
Tính thân thiện	Rất cao (trong suốt với người dùng)	Thấp (đòi hỏi kiến thức kỹ thuật)

3.2 Định nghĩa và mục tiêu PKI

Như đã đề cập, Hạ tầng khóa công khai (PKI) là một bộ khung bao gồm các thành phần công nghệ (phần cứng, phần mềm), cơ cấu tổ chức (con người), và các tài liệu điều chỉnh (chính sách, quy trình) nhằm mục đích phát hành, duy trì, và thu hồi các chứng chỉ số số trong một môi trường mạng mở.

Mục tiêu lớn nhất của PKI là giải quyết bài toán cốt lõi về "sự tin cậy" (trust) trên môi trường số bằng cách cung cấp một cơ chế bảo đảm để gắn kết (bind) một danh tính thực (một con người, một tổ chức, hoặc một thiết bị) với một khóa công khai cụ thể thông qua bên thứ ba được tin tưởng là CA. Quan trọng hơn, PKI không chỉ dừng lại ở các giao thức kỹ thuật, mà nó mang đậm tính chất quản trị (governance) – giải quyết các vấn đề vĩ mô như: ai có đủ thẩm quyền để làm CA? Tiêu chuẩn nào CA phải tuân thủ để được đưa vào Trust Store của các trình duyệt?

****Ứng dụng của public key: Chữ ký số**** Sau khi PKI đã thiết lập sự tin cậy trong khóa công khai của một thực thể (thông qua việc cấp chứng chỉ số), thực thể đó có thể sử dụng cặp khóa của mình để đạt được các mục tiêu an toàn thông tin cụ thể, như được minh họa trong Hình 3.1. Sơ đồ này cho thấy quy trình tạo và xác thực chữ ký số, giúp đảm bảo tính toàn vẹn (Integrity) và tính xác thực (Authentication) của thông điệp được truyền đi.

Sử dụng khóa bí mật (Private Key) để ký số lên hàm băm (Message Digest) tạo ra một bằng chứng không thể phủ nhận về nguồn gốc của thông điệp. Khi người nhận dùng khóa công khai tương ứng để xác thực thành công, họ biết chắc rằng thông điệp thực sự đến từ chủ sở hữu khóa và không bị chỉnh sửa trên đường truyền. Đây chính là một trong

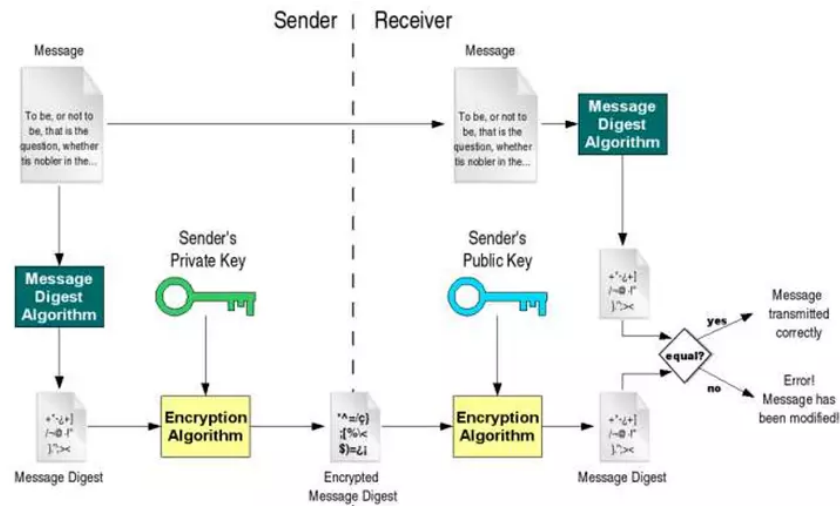


Figure 3.1: Quy trình tạo và xác thực chữ ký số sử dụng cặp khóa công khai và bí mật.

những mục tiêu hoạt động then chốt mà PKI hướng tới nhằm tạo ra sự tin cậy tổng thể.

3.3 Các thành phần PKI

CA – Certificate Authority

Certificate Authority (Tổ chức phát hành chứng chỉ) là trái tim của hệ thống PKI. CA chịu trách nhiệm chính trong việc phát hành, thu hồi chứng chỉ và duy trì danh sách chứng chỉ bị thu hồi (CRL). Để tối ưu hóa tính bảo mật, các CA thường được tổ chức theo cấu trúc phân tầng. Trên cùng là Root CA, nắm giữ khóa quan trọng nhất và thường được giữ ở trạng thái ngoại tuyến (offline, air-gapped) để tránh bị tấn công mạng. Root CA ký cấp phát chứng chỉ cho các Intermediate CA (CA trung gian), và các Intermediate CA này mới là đơn vị trực tiếp tương tác và cấp phát chứng chỉ cho thực thể cuối (Leaf/End-entity). Quy trình cơ bản bao gồm: người dùng tạo Yêu cầu ký chứng chỉ (CSR) → CA xác minh danh tính → CA dùng khóa bí mật để ký chứng chỉ → Công bố chứng chỉ.

RA – Registration Authority

Registration Authority (Tổ chức đăng ký) hoạt động như một cơ quan tiền phương cho CA. Việc tách bạch quá trình xác minh danh tính (thực hiện bởi RA) khỏi quá trình ký chứng chỉ (thực hiện bởi CA) giúp phân quyền trách nhiệm và giảm thiểu rủi ro bảo mật cho hệ thống ký. RA đóng vai trò kiểm tra tính hợp lệ của người nộp đơn. Ví dụ trong thực tế, RA có thể yêu cầu người dùng xuất trình Căn cước công dân hoặc Hộ chiếu để đối chiếu; sau khi RA xác nhận hợp lệ, yêu cầu mới được chuyển tiếp để CA thực hiện thao tác ký số sinh ra chứng chỉ.

Repository – Kho lưu trữ chứng chỉ

Kho lưu trữ (Repository) là cơ sở dữ liệu công khai lưu trữ các chứng chỉ đang có hiệu lực và danh sách các chứng chỉ đã bị thu hồi. Kho này thường được triển khai trên các máy chủ thư mục LDAP (Lightweight Directory Access Protocol) hoặc máy chủ HTTP/HTTPS, đảm bảo các client có thể truy vấn nhanh chóng để lấy chứng chỉ của người cần giao tiếp hoặc kiểm tra trạng thái CRL bất cứ lúc nào.

CRL – Certificate Revocation List

Danh sách chứng chỉ bị thu hồi (CRL) là một tài liệu được CA ký số và phát hành định kỳ, liệt kê số seri của các chứng chỉ đã bị mất hiệu lực trước khi hết hạn. Các lý do thu hồi (reason codes) thường được đi kèm, ví dụ như lộ khóa bí mật (`keyCompromise`) hoặc bản thân CA bị xâm phạm (`cACompromise`). Hạn chế lớn của CRL là kích thước tệp có thể phình to rất nhanh và thông tin không được cập nhật tức thời (có thể lỗi thời - stale trong nhiều giờ hoặc vài ngày trước khi bản mới được tải về). Để giảm tải mạng, giải pháp `delta CRL` [3] được sử dụng để chỉ tải xuống những thay đổi so với bản CRL đầy đủ trước đó.

OCSP – Online Certificate Status Protocol

Giao thức kiểm tra trạng thái chứng chỉ trực tuyến (OCSP) [4] ra đời nhằm khắc phục độ trễ của CRL. Thay vì tải toàn bộ danh sách, client gửi truy vấn chứa số seri của chứng chỉ đến máy chủ OCSP Responder và nhận về phản hồi theo thời gian thực (Realtime) về trạng thái hợp lệ của chứng chỉ đó. Để giải quyết vấn đề về quyền riêng tư (vì CA biết client đang truy cập trang web nào) và độ trễ (latency) khi client phải tự liên hệ CA, kỹ thuật **OCSP Stapling** [5] được áp dụng. Máy chủ web sẽ tự động lấy (pre-fetch) phản hồi OCSP có chữ ký của CA theo định kỳ, sau đó "gắn kèm" (staple) bằng chứng này vào quá trình thiết lập kết nối TLS ban đầu với client.

Table 3.2: So sánh các phương pháp kiểm tra trạng thái thu hồi chứng chỉ

Tiêu chí	CRL	OCSP	OCSP Stapling
Độ trễ cập nhật	Cao (phụ thuộc chu kỳ tải)	Thấp (thời gian thực)	Thấp (thời gian thực, có cache)
Chi phí băng thông	Rất cao (tải toàn bộ list)	Thấp	Rất thấp
Quyền riêng tư	Tốt (Client kiểm tra cục bộ)	Kém (CA biết lịch sử duyệt web)	Tốt (Client không gọi trực tiếp CA)

3.4 Chu kỳ sống của chứng chỉ

Hoạt động của PKI phụ thuộc vào việc quản lý chặt chẽ vòng đời (lifecycle) của một chứng chỉ số. Chu kỳ sống này bao gồm các giai đoạn tuần tự:

1. **Tạo cặp khóa (Keypair Generation):** Thực thể tự tạo Khóa công khai và Khóa bí mật một cách an toàn.
2. **Tạo yêu cầu (CSR Creation):** Gói Khóa công khai và các thông tin định danh vào một bản tin CSR (Certificate Signing Request).
3. **Xác minh (Verification):** RA/CA kiểm tra tính hợp lệ của thông tin và quyền sở hữu tên miền/tổ chức.
4. **Phát hành (Issuance):** CA ký điện tử lên CSR để tạo ra chứng chỉ số hợp lệ.
5. **Sử dụng (Usage):** Chứng chỉ được triển khai trên hệ thống (web server, email) để thực hiện mã hóa và xác thực.
6. **Gia hạn / Thu hồi (Renewal / Revocation):** Trước khi hết hạn, chứng chỉ cần được gia hạn. Nếu khóa bí mật bị lộ hoặc thông tin không còn đúng, chứng chỉ sẽ bị đưa vào quá trình thu hồi (đưa vào CRL hoặc báo trạng thái qua OCSP).

Với sự bùng nổ của quy mô dịch vụ đám mây và microservices, việc cấu hình thủ công không còn khả thi. Tự động hóa vòng đời chứng chỉ (Certificate Lifecycle Automation) thông qua các giao thức như ACME (được Let's Encrypt sử dụng phổ biến), SCEP, hoặc EST ngày càng đóng vai trò quan trọng yếu giúp đảm bảo hệ thống không bị gián đoạn dịch vụ do chứng chỉ hết hạn.

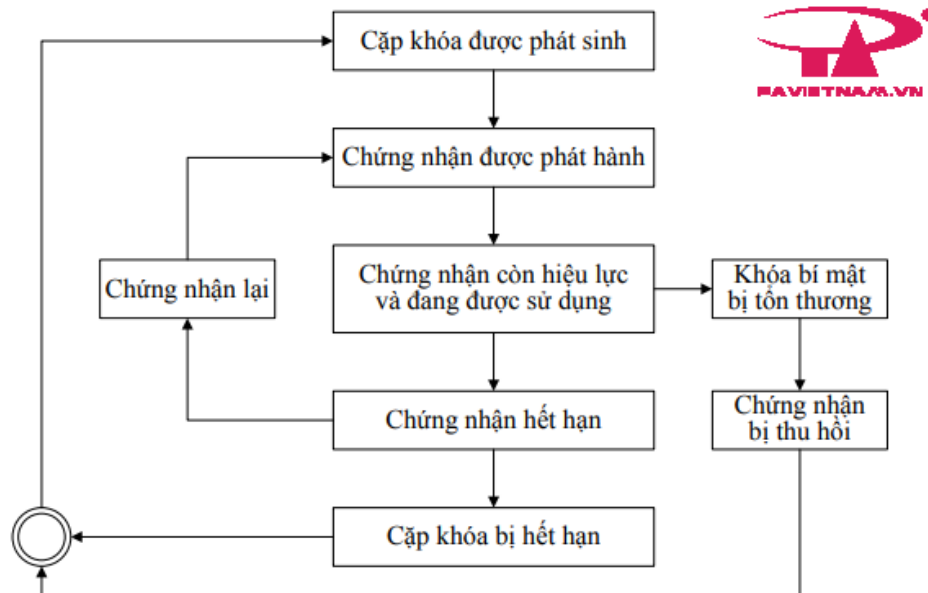


Figure 3.2: Sơ đồ chu kỳ sống của chứng chỉ số trong hệ thống PKI

Chapter 4

Chứng chỉ số và các chuẩn

Chứng chỉ số là đối tượng dữ liệu mà PKI phát hành và kiểm tra. Với chứng chỉ X.509, một CA ký lên dữ liệu gồm danh tính, khóa công khai, thời hạn hiệu lực và các ràng buộc sử dụng. Bên nhận không cần biết trước khóa công khai của chủ thể. Họ kiểm tra chữ ký của CA, chuỗi chứng chỉ, thời hạn, trạng thái thu hồi và tên được chứng nhận.

4.1 Chứng chỉ số X.509

X.509 xuất phát từ hệ thư mục X.500 của ITU-T. Trong Web PKI hiện nay, cách diễn giải được dùng rộng rãi là hồ sơ Internet X.509 do RFC 5280 định nghĩa cho chứng chỉ và CRL [3]. Phiên bản 1 chứa các trường cơ bản. Phiên bản 2 thêm định danh riêng cho issuer và subject. Phiên bản 3 bổ sung cơ chế extension, nhờ đó cùng một khuôn dạng chứng chỉ có thể biểu diễn CA, máy chủ TLS, người dùng email, thiết bị hoặc chứng chỉ ký mã.

Một chứng chỉ X.509 gồm ba phần ở mức ASN.1. Phần `tbsCertificate` là dữ liệu “to be signed”: CA ký đúng phần này. Phần thuật toán chữ ký cho biết thuật toán được dùng, chẳng hạn RSA với SHA-256 hoặc ECDSA với SHA-256. Phần giá trị chữ ký chứa chữ ký trên `tbsCertificate`. Cấu trúc này cho phép bên kiểm tra tái tạo dữ liệu đã ký và xác minh bằng khóa công khai của issuer.

X.509 được mã hóa theo DER trong tầng nhị phân. DER là một dạng mã hóa xác định của ASN.1, nên cùng một cấu trúc dữ liệu có đúng một biểu diễn byte hợp lệ. PEM là lớp bao gói văn bản: dữ liệu DER được mã hóa Base64 và đặt giữa các dòng `---BEGIN CERTIFICATE---` và `---END CERTIFICATE---`. Vì vậy, DER và PEM không phải hai loại chứng chỉ khác nhau. Chúng là hai cách biểu diễn cùng một nội dung.

Table 4.1: Các trường chính trong chứng chỉ X.509 v3

Trường	Ý nghĩa	Ghi chú
version	Phiên bản khuôn dạng chứng chỉ.	Web PKI thực tế dùng v3 để hỗ trợ extension.
serialNumber	Số seri do CA gán trong phạm vi issuer.	Được dùng khi thu hồi qua CRL hoặc OCSP.
issuer	DN của thực thể ký chứng chỉ.	Thường là CA trung gian hoặc root CA.
validity	Cặp thời điểm notBefore và notAfter .	Chứng chỉ chỉ hợp lệ trong khoảng này.
subject	DN của chủ thể được cấp chứng chỉ.	Có thể rỗng nếu danh tính nằm trong SAN.
subjectPublicKeyInfo	Thuật toán khóa công khai và giá trị khóa.	Ví dụ RSA, ECDSA hoặc EdDSA.
extensions	Các ràng buộc và thuộc tính mở rộng.	Là cơ chế trung tâm của X.509 v3.

4.2 Các trường X.509 v3

Trường **version** xác định cách diễn giải chứng chỉ. Với X.509 v3, trường **extensions** trở thành bắt buộc về mặt thực tiễn vì phần lớn kiểm tra an toàn nằm ở đây. Trường **serialNumber** phải đủ phân biệt trong phạm vi issuer để có thể định danh chứng chỉ khi thu hồi. Trường **issuer** cho biết tên của CA ký chứng chỉ; trường **subject** cho biết tên của thực thể nhận chứng chỉ.

Trường **validity** gồm **notBefore** và **notAfter**. Bên kiểm tra phải từ chối chứng chỉ nếu thời điểm hiện tại nằm ngoài khoảng này. Trường **subjectPublicKeyInfo** chứa khóa công khai của subject cùng định danh thuật toán. Với chứng chỉ máy chủ, đây là khóa được dùng để xác thực chữ ký hoặc tham gia cơ chế trao đổi khóa tùy giao thức phía trên. Chi tiết bắt tay TLS không được trình bày ở đây, vì thuộc phạm vi Chương 5.

4.3 Distinguished Name

Distinguished Name (DN) là tên phân cấp theo mô hình X.500. Trong chứng chỉ, DN thường xuất hiện ở **issuer** và **subject**. Các thuộc tính thường gặp gồm **C** cho quốc gia, **ST** cho bang hoặc tỉnh, **L** cho địa phương, **O** cho tổ chức, **OU** cho đơn vị tổ chức, **CN** cho common name và **emailAddress** cho địa chỉ thư điện tử. DN hữu ích trong môi trường tổ chức vì nó mô tả subject bằng các thuộc tính có cấu trúc.

Trong HTTPS, **CN** không còn là nơi chính để kiểm tra tên miền. RFC 6125 yêu cầu ứng dụng ưu tiên subject alternative name và không quay lại **CN** khi SAN thuộc loại tên phù hợp đã có mặt [6]. Điều này tách rõ tên hiển thị trong DN khỏi tập tên mà chứng chỉ thực sự chứng nhận. Với chứng chỉ máy chủ, SAN mới là nơi chứa DNS name hoặc IP

address được so khớp với tên mà client truy cập.

4.4 Extension quan trọng

Extension làm cho X.509 v3 phù hợp với nhiều ngữ cảnh sử dụng. Mỗi extension có định danh OID, giá trị và cờ critical. Nếu một extension critical không được hiểu, bên kiểm tra phải từ chối chứng chỉ theo RFC 5280 [3]. Cơ chế này cho phép CA áp đặt điều kiện an toàn mà client không được bỏ qua.

Table 4.2: Một số extension thường gặp trong X.509 v3

Extension	Nội dung	Vai trò
BasicConstraints	Cờ cA và tùy chọn pathLenConstraint.	Phân biệt CA với end-entity certificate.
KeyUsage	Bit như digitalSignature, keyEncipherment, keyCertSign.	Giới hạn thao tác mật mã được phép.
ExtendedKeyUsage	OID mục đích như server authentication, client authentication hoặc code signing.	Thu hẹp ngữ cảnh sử dụng của khóa.
SubjectAltName	DNS name, IP address, email hoặc URI của subject.	Cơ sở kiểm tra tên miền trong Web PKI.
SubjectKeyIdentifier	Định danh suy ra từ khóa công khai của subject.	Hỗ trợ tìm và nối chuỗi chứng chỉ.
AuthorityKeyIdentifier	Định danh khóa của issuer.	Ghép chứng chỉ với CA đã ký nó.
CRLDistributionPoints	Vị trí tải CRL.	Cho phép client kiểm tra thu hồi bằng CRL.
AuthorityInfoAccess	Vị trí OCSP responder hoặc chứng chỉ issuer.	Hỗ trợ kiểm tra trạng thái và dựng chuỗi.

BasicConstraints là extension bắt buộc về mặt an toàn với CA certificate. Nếu cA bằng TRUE, chứng chỉ có thể được dùng để ký chứng chỉ khác, với điều kiện các trường khác như **KeyUsage** cũng cho phép. **pathLenConstraint** giới hạn số CA trung gian có thể xuất hiện bên dưới CA đó trong chuỗi chứng chỉ.

KeyUsage mô tả thao tác mật mã cấp thấp. Ví dụ, **digitalSignature** cho phép dùng khóa để kiểm tra chữ ký số, trong khi **keyCertSign** chỉ phù hợp với CA. Ngược lại, **ExtendedKeyUsage** mô tả mục đích ứng dụng. Một chứng chỉ có thể chứa khóa hợp lệ về mặt thuật toán nhưng vẫn bị từ chối nếu ECU không chứa mục đích mà ứng dụng cần.

SubjectAltName chứa các tên được chứng nhận cho subject. Với chứng chỉ website, SAN thường chứa một hoặc nhiều DNS name. **SubjectKeyIdentifier** và **AuthorityKeyIdentifier** không tự tạo ra niềm tin, nhưng giúp phần mềm chọn đúng issuer khi có nhiều chứng chỉ CA cùng tên hoặc cùng tổ chức. Hai extension **CRLDistributionPoints** và **AuthorityInfoAccess** liên kết chứng chỉ với hạ tầng kiểm tra thu hồi qua CRL và OCSP [4].

4.5 Certificate Signing Request

Certificate Signing Request (CSR) là yêu cầu ký chứng chỉ do chủ thể gửi cho CA. Khuôn dạng CSR phổ biến là PKCS #10, được RFC 2986 mô tả [7]. CSR chứa thông tin subject, khóa công khai, một tập thuộc tính tùy chọn và chữ ký do chính khóa bí mật ứng với khóa công khai trong CSR tạo ra. Chữ ký này chứng minh rằng người gửi CSR có quyền kiểm soát khóa bí mật, nhưng nó không chứng minh danh tính pháp lý hoặc quyền sở hữu tên miền. Phần đó thuộc trách nhiệm xác minh của RA hoặc CA.

Luồng cấp chứng chỉ có bốn bước. Thứ nhất, subject tạo cặp khóa và bảo vệ khóa bí mật cục bộ. Thứ hai, subject tạo CSR chứa khóa công khai và thông tin định danh mong muốn. Thứ ba, CA kiểm tra quyền kiểm soát tên miền, thông tin tổ chức hoặc tiêu chí tương ứng với loại chứng chỉ. Thứ tư, CA ký dữ liệu X.509 và trả lại chứng chỉ. Khóa bí mật không cần rời khỏi hệ thống của subject trong luồng thông thường.

4.6 Phân loại chứng chỉ

CA/Browser Forum Baseline Requirements định nghĩa yêu cầu tối thiểu cho chứng chỉ máy chủ TLS được tin cậy công khai, bao gồm quy trình xác minh tên miền, thông tin subject và vận hành CA [2]. Trong thực tế, chứng chỉ TLS thường được phân loại theo mức xác minh danh tính: domain validation (DV), organization validation (OV) và extended validation (EV). DV xác minh quyền kiểm soát tên miền. OV thêm kiểm tra tổ chức. EV áp dụng bộ yêu cầu nhận diện tổ chức chặt hơn theo tài liệu EV riêng của CA/Browser Forum [8].

Table 4.3: Phân loại chứng chỉ theo mục đích sử dụng

Loại	Đặc điểm	Cách dùng
DV	Xác minh quyền kiểm soát tên miền.	Website công khai, tự động hóa cấp phát.
OV	Xác minh thêm thông tin tổ chức.	Dịch vụ cần hiện thông tin pháp nhân rõ hơn.
EV	Xác minh tổ chức theo yêu cầu EV.	Môi trường cần quy trình nhận diện chặt hơn.
Wildcard	Tên dạng *.example.com.	Nhiều subdomain cùng một cấp.
Multi-domain/SAN	Nhiều tên trong SubjectAltName.	Gom nhiều DNS name vào một chứng chỉ.
Code signing	EKU cho ký mã hoặc chính sách tương ứng.	Ký phần mềm, script hoặc gói cài đặt.
S/MIME	Gắn khóa công khai với địa chỉ email.	Ký và mã hóa thư điện tử [9].
Client certificate	Subject đại diện người dùng, thiết bị hoặc dịch vụ.	Xác thực client trong VPN, mTLS hoặc hệ nội bộ.

Wildcard certificate chỉ bao phủ một cấp nhân theo cách diễn giải thông thường của Web PKI. Ví dụ, *.example.com có thể khớp www.example.com, nhưng không khớp a.b.example.com. Multi-domain certificate dùng SAN để chứa nhiều tên cụ thể. Cách này phù hợp khi một dịch vụ có nhiều tên miền hoặc khi cần hợp nhất chứng chỉ cho các endpoint liên quan.

4.7 Các chuẩn PKCS

PKCS là họ chuẩn ban đầu do RSA Laboratories công bố cho các đối tượng mật mã trong triển khai thực tế. Trong phạm vi chứng chỉ số, ba chuẩn cần quan tâm là PKCS #7/CMS, PKCS #10 và PKCS #12. Báo cáo không liệt kê toàn bộ họ PKCS vì nhiều chuẩn đã lỗi thời hoặc nằm ngoài trọng tâm PKI.

PKCS #7 định nghĩa cú pháp cho dữ liệu được ký hoặc mã hóa. Hậu thân chuẩn hóa trong IETF là Cryptographic Message Syntax (CMS), được RFC 5652 mô tả [10]. CMS là nền tảng cho nhiều định dạng chữ ký và thông điệp bảo mật, trong đó có S/MIME. PKCS #10 là định dạng CSR như đã trình bày ở Mục 4.5. PKCS #12 định nghĩa định dạng đóng gói khóa bí mật, chứng chỉ và chuỗi chứng chỉ vào một tệp, thường có phần bảo vệ bằng mật khẩu; RFC 7292 mô tả định dạng này [11]. Tệp .p12 hoặc .pfx thường được dùng khi xuất nhập chứng chỉ người dùng hoặc chứng chỉ máy chủ giữa các hệ thống.

4.8 RFC và chuẩn quan trọng

RFC 5280 là chuẩn nền tảng cho hồ sơ Internet X.509, bao gồm cấu trúc chứng chỉ, extension, thuật toán dựng đường chứng chỉ và CRL [3]. RFC 2986 định nghĩa PKCS #10 cho CSR [7]. RFC 5652 định nghĩa CMS, là khuôn dạng chung cho dữ liệu ký số và mã hóa ở tầng thông điệp [10]. RFC 7292 định nghĩa PKCS #12 cho gói khóa và chứng chỉ [11].

RFC 6960 định nghĩa OCSP, giao thức hỏi trạng thái thu hồi cho một chứng chỉ cụ thể [4]. RFC 6962 định nghĩa Certificate Transparency phiên bản thử nghiệm, trong đó chứng chỉ TLS được ghi vào log công khai dựa trên cây Merkle [12]. Các triển khai mới hơn có thể tham chiếu RFC 9162 cho Certificate Transparency phiên bản 2.0 [13]. CA/Browser Forum Baseline Requirements không thay thế RFC, nhưng đặt yêu cầu vận hành cho CA muốn được tin cậy trong hệ sinh thái trình duyệt [2]. Vì vậy, Web PKI là kết quả của cả chuẩn kỹ thuật và quy tắc quản trị CA.

Chapter 5

Triển khai và ứng dụng thực tế

PKI đi vào hệ thống thực tế bằng một mẫu chung. Một thực thể cần chứng minh danh tính hoặc quyền phát hành. Thực thể đó dùng chứng chỉ để gắn danh tính với khóa công khai. Bên nhận kiểm tra chuỗi chứng chỉ, mục đích sử dụng khóa và trạng thái hiệu lực trước khi tin vào chữ ký hoặc khóa phiên.

Chương này không lặp lại cấu trúc X.509 đã trình bày ở Chương 4. Trọng tâm là vai trò vận hành của PKI trong HTTPS, ký số tài liệu, S/MIME, VPN, ký mã và dịch vụ công điện tử.

Table 5.1: So sánh một số ứng dụng PKI

Ứng dụng	Đối tượng xác thực	Loại chứng chỉ	Kiểm tra chính	Rủi ro vận hành
HTTPS/TLS	Máy chủ dịch vụ	TLS server certificate	Chuỗi CA, SAN, thời hạn, KU/EKU, thu hồi nếu có	Sai hostname, thiếu intermediate CA, khóa máy chủ bị lộ.
Ký số tài liệu	Người ký hoặc tổ chức	Chứng chỉ ký số cá nhân, tổ chức hoặc dịch vụ ký từ xa	Chữ ký tài liệu, chuỗi CA, thời điểm ký, trạng thái thu hồi	Không có timestamp tin cậy, khóa ký bị dùng ngoài kiểm soát.
S/MIME	Người gửi và người nhận email	Chứng chỉ gắn với địa chỉ email	Chữ ký email, chứng chỉ người gửi, chứng chỉ người nhận khi mã hóa	Khó quản lý chứng chỉ người dùng, mất khóa giải mã.
VPN/IPSec	Gateway, client hoặc site ngang hàng	Chứng chỉ thiết bị hoặc người dùng	CERT, CERTREQ, AUTH trong IKEv2, chuỗi CA nội bộ	CA nội bộ yếu, cấp chứng chỉ sai danh tính, thu hồi chậm.
Code signing	Nhà phát hành phần mềm	Code signing certificate	Chữ ký mã, certificate chain, timestamp, trạng thái thu hồi	Private key bị lộ, pipeline build bị chiếm quyền.
eGovernment	Công dân, tổ chức, cơ quan, dịch vụ ký số	Chứng chỉ công cộng hoặc chứng chỉ ký số từ xa	Chữ ký văn bản, chứng chỉ người ký, timestamp, OCSP/CRL	Liên thông hệ thống, vòng đời chứng chỉ, trải nghiệm người dùng.

5.1 HTTPS / TLS

Bài toán thực tế. Client cần biết mình đang nói chuyện với đúng máy chủ. Nếu chỉ có mã hóa kênh truyền, kẻ trung gian vẫn có thể đưa khóa công khai giả. Trong Web PKI,

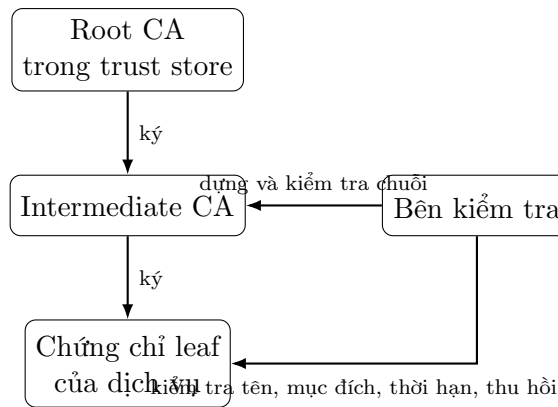


Figure 5.1: Mẫu kiểm tra PKI trong ứng dụng thực tế

chứng chỉ máy chủ TLS giải quyết bài toán gắn khóa công khai với DNS name mà người dùng truy cập.

Cách PKI giải quyết. Trong TLS 1.3, máy chủ thường gửi thông điệp **Certificate** chứa chứng chỉ leaf và các chứng chỉ trung gian cần thiết. Máy chủ sau đó dùng khóa bí mật tương ứng để tạo **CertificateVerify**, qua đó chứng minh quyền kiểm soát khóa trong chứng chỉ [14]. Root CA không được gửi như một bằng chứng mới. Nó phải có sẵn trong trust store của hệ điều hành hoặc trình duyệt.

Certificate chain nối từ leaf đến intermediate CA, rồi đến root CA được tin cậy. Leaf certificate chứng nhận tên miền dịch vụ. Intermediate CA giảm rủi ro cho root CA vì root có thể được giữ offline. Root CA là điểm neo tin cậy mà client dùng để kết thúc quá trình dựng chuỗi.

Luồng kiểm tra. Client kiểm tra chữ ký trên từng mắt xích của chuỗi. Nó từ chối chứng chỉ nếu thời điểm hiện tại nằm ngoài khoảng hiệu lực. Tên truy cập phải khớp với DNS name hoặc IP address trong SAN, theo nguyên tắc đã nêu ở Mục 4.3. Client cũng kiểm tra **KeyUsage** và **ExtendedKeyUsage** để bảo đảm chứng chỉ phù hợp với xác thực máy chủ.

Kiểm tra thu hồi có thể dùng CRL, OCSP hoặc OCSP stapling. OCSP được RFC 6960 định nghĩa cho truy vấn trạng thái của một chứng chỉ cụ thể [4]. OCSP stapling cho phép máy chủ gửi kèm phản hồi OCSP trong TLS, thay vì để client tự hỏi responder của CA [5]. Certificate Transparency bổ sung khả năng giám sát cấp phát chứng chỉ TLS bằng log công khai. RFC 9162 mô tả CT như một cơ chế ghi nhận chứng chỉ và precertificate trong log có thể kiểm toán [13].

ACME tự động hóa quá trình yêu cầu, xác minh quyền kiểm soát tên miền, cấp, gia hạn và thu hồi chứng chỉ. RFC 8555 định nghĩa giao thức này, thường được biết đến qua hệ sinh thái Let's Encrypt [15]. ACME không thay thế kiểm tra PKI ở phía client. Nó làm giảm lỗi vận hành ở phía cấp và gia hạn chứng chỉ.

Lỗi và rủi ro triển khai. Lỗi phổ biến là thiếu intermediate CA trong cấu hình máy chủ. Khi đó một số client không dựng được chuỗi, dù leaf certificate hợp lệ. Lỗi khác là chứng chỉ không chứa đúng SAN, hết hạn, dùng sai EKU, hoặc private key bị sao chép khỏi máy chủ. Trong môi trường nhiều dịch vụ, tự động hóa gia hạn phải đi kèm giám sát. Một chứng chỉ hết hạn có thể làm ngừng dịch vụ dù hệ thống ứng dụng vẫn hoạt động.

5.2 Chữ ký số văn bản

Bài toán thực tế. Văn bản điện tử cần cơ chế kiểm tra người ký và phát hiện sửa đổi sau khi ký. Việc chèn hình ảnh chữ ký không cung cấp bảo đảm mật mã. Nó không chứng minh người ký kiểm soát khóa bí mật, và cũng không ràng buộc toàn vẹn tài liệu.

Cách PKI giải quyết. Luồng ký số bắt đầu bằng việc tính giá trị băm của tài liệu hoặc cấu trúc dữ liệu cần ký. Phần mềm ký dùng private key để ký giá trị đó. Chữ ký, chứng chỉ người ký và có thể cả chuỗi chứng chỉ được gắn vào tài liệu hoặc gói chữ ký. Người nhận dùng public key trong chứng chỉ để kiểm tra chữ ký, rồi kiểm tra chuỗi CA và trạng thái chứng chỉ.

Chữ ký số, chứng chỉ và timestamp có vai trò khác nhau. Chữ ký số ràng buộc tài liệu với private key. Chứng chỉ ràng buộc public key với danh tính người ký hoặc tổ chức. Timestamp ghi nhận rằng chữ ký đã tồn tại tại một thời điểm do Time Stamping Authority xác nhận. RFC 3161 định nghĩa Time-Stamp Protocol cho hạ tầng X.509 [16].

Luồng kiểm tra. Bên nhận kiểm tra chữ ký trên tài liệu trước. Sau đó họ kiểm tra chứng chỉ người ký, bao gồm chain, thời hạn, mục đích sử dụng khóa và trạng thái thu hồi. Nếu tài liệu có timestamp đáng tin cậy, bên nhận có thể đánh giá chữ ký tại thời điểm ký. Điều này giúp kiểm chứng tài liệu sau khi chứng chỉ người ký đã hết hạn, miễn là chứng chỉ còn hợp lệ tại thời điểm được đóng dấu.

Với tài liệu PDF, chữ ký số thường được chuẩn hóa theo các profile riêng của hệ sinh thái tài liệu. Báo cáo này chỉ dùng khái niệm ở mức PKI: tài liệu được ký, chứng chỉ được đính kèm, và timestamp giúp bảo vệ giá trị xác minh theo thời gian. Phần chi tiết định dạng PDF không phải trọng tâm của chương.

Lỗi và rủi ro triển khai. Rủi ro chính là bảo vệ private key. Nếu khóa ký nằm trên máy người dùng mà không có thiết bị bảo vệ hoặc chính sách truy cập phù hợp, chữ ký có thể bị tạo ngoài ý chí người ký. Timestamp cũng cần nguồn tin cậy. Nếu tài liệu chỉ có thời gian hệ thống cục bộ, verifier khó phân biệt chữ ký hợp lệ trước khi hết hạn với chữ ký được tạo muộn sau đó.

5.3 S/MIME

Bài toán thực tế. Email mặc định không cung cấp xác thực mạnh cho nội dung từng thư. Người nhận cần biết thư có thật do người gửi tạo ra không. Khi cần bí mật nội dung, người gửi cũng cần mã hóa thư cho đúng người nhận.

Cách PKI giải quyết. S/MIME dùng chứng chỉ X.509 gắn với địa chỉ email. RFC 8551 định nghĩa S/MIME 4.0 cho ký và mã hóa dữ liệu MIME [9]. Khi ký email, người gửi dùng private key của mình để tạo chữ ký. Người nhận dùng chứng chỉ của người gửi để kiểm tra chữ ký và chuỗi CA.

Khi mã hóa email, người gửi cần chứng chỉ của từng người nhận. Nội dung thư thường được mã hóa bằng khóa phiên. Khóa phiên đó được bảo vệ bằng public key của người nhận. Chỉ người có private key tương ứng mới giải mã được nội dung.

Luồng kiểm tra. Với thư ký số, client email kiểm tra chữ ký trên nội dung, sau đó kiểm tra chứng chỉ người gửi. Với thư mã hóa, người nhận dùng private key của mình để mở khóa phiên, rồi giải mã nội dung. Nếu thư vừa ký vừa mã hóa, verifier cần xử lý cả hai lớp. Thứ tự xử lý phụ thuộc vào định dạng thông điệp cụ thể.

S/MIME khác PGP ở mô hình tin cậy. S/MIME dựa vào CA và chứng chỉ X.509. PGP thường gắn với Web of Trust hoặc cơ chế tự quản lý khóa. Điều này làm S/MIME phù hợp hơn với tổ chức có PKI tập trung, nhưng phụ thuộc vào cấp phát và quản trị chứng chỉ người dùng.

Lỗi và rủi ro triển khai. Vấn đề thực tế lớn nhất là vòng đời chứng chỉ người dùng. Người dùng có thể đổi máy, mất private key, hoặc dùng nhiều client email khác nhau. Nếu private key mã hóa bị mất, thư cũ có thể không đọc lại được. Nếu tổ chức cấp chứng chỉ cho nhiều địa chỉ hoặc đổi địa chỉ email, chính sách ánh xạ danh tính cần rõ ràng.

5.4 VPN và IPSec

Bài toán thực tế. VPN cần xác thực hai đầu kết nối trước khi thiết lập kênh bảo vệ. Trong mô hình site-to-site, hai gateway cần nhận ra nhau. Trong mô hình remote access, gateway cần xác thực client hoặc người dùng. Nếu chỉ dùng một pre-shared key chung, việc mở rộng và thu hồi quyền truy cập trở nên khó kiểm soát.

Cách PKI giải quyết. IKEv2 thiết lập Security Association cho IPSec. RFC 7296 mô tả việc các peer có thể dùng payload CERT, CERTREQ và AUTH trong trao đổi IKE_AUTH [17]. Chứng chỉ cung cấp public key và danh tính. Payload AUTH chứng minh peer sở hữu private key tương ứng.

Tổ chức thường dùng CA nội bộ cho VPN. CA cấp chứng chỉ cho gateway, thiết bị hoặc người dùng. Gateway tin root CA nội bộ và kiểm tra chứng chỉ client theo chính sách truy cập. Hai gateway site-to-site có thể xác thực lẫn nhau bằng chứng chỉ do cùng một CA hoặc các CA được liên thông cấp.

Luồng kiểm tra. Peer gửi danh tính, chứng chỉ và bằng chứng xác thực. Bên nhận dựng chuỗi tới CA được tin cậy, kiểm tra thời hạn và trạng thái thu hồi, rồi kiểm tra rằng danh tính trong chứng chỉ phù hợp với chính sách VPN. Với mutual authentication, cả hai phía đều thực hiện quy trình này. Sau khi xác thực thành công, IKEv2 tạo các Child SA để bảo vệ lưu lượng ESP hoặc AH.

Lỗi và rủi ro triển khai. Certificate-based VPN mở rộng tốt hơn pre-shared key vì mỗi thiết bị hoặc người dùng có thể có chứng chỉ riêng. Khi một client mất quyền, CA có thể thu hồi chứng chỉ đó mà không đổi bí mật của toàn hệ thống. Đổi lại, tổ chức phải vận hành PKI nghiêm túc. Lỗi cấu hình CA, bỏ qua thu hồi, cấp chứng chỉ sai identity hoặc lưu private key gateway không an toàn đều làm giảm lợi ích của mô hình này.

5.5 Code Signing

Bài toán thực tế. Người dùng và hệ điều hành cần biết phần mềm đến từ nhà phát hành nào và có bị sửa sau khi ký không. Kênh tải xuống không đủ để bảo đảm hai điều này. Một file có thể bị thay đổi trên mirror, trong quá trình phân phối, hoặc trong pipeline phát hành.

Cách PKI giải quyết. Code signing gắn chữ ký số vào phần mềm, script, driver hoặc gói cài đặt. Microsoft mô tả chữ ký số trên file như một cách nhận diện nhà phân phối và bảo đảm nội dung không đổi sau khi chữ ký được tạo [18]. Apple cũng mô tả code signing như cơ chế xác minh tính toàn vẹn ứng dụng và danh tính nhà phát triển [19].

Chứng chỉ ký mã khác chứng chỉ TLS ở mục đích sử dụng. Nó không dùng để chứng minh DNS name của máy chủ. Nó dùng cho publisher hoặc tổ chức phát hành phần mềm. Sự khác biệt này thường được thể hiện bằng EKU, chính sách chứng chỉ và quy tắc của nền tảng kiểm tra.

Luồng kiểm tra. Khi cài hoặc chạy phần mềm, hệ thống kiểm tra chữ ký trên file. Nếu chữ ký hợp lệ, hệ thống dựng chuỗi chứng chỉ của publisher tới một root được tin cậy. Nó cũng có thể kiểm tra timestamp và trạng thái thu hồi. Timestamp giúp phân biệt phần mềm đã được ký khi chứng chỉ còn hợp lệ với phần mềm được ký sau khi chứng chỉ hết hạn hoặc bị thu hồi.

Lỗi và rủi ro triển khai. Rủi ro nghiêm trọng nhất là private key ký mã bị lộ. Khi đó kẻ tấn công có thể ký mã độc dưới danh tính hợp lệ cho tới khi chúng chỉ bị thu hồi và các nền tảng cập nhật trạng thái. Một rủi ro khác là build pipeline bị compromise. Trong trường hợp đó, phần mềm độc hại có thể được ký bằng khóa thật của tổ chức. Vì vậy, code signing cần kiểm soát khóa, kiểm soát pipeline và quy trình thu hồi rõ ràng.

5.6 eGovernment Việt Nam

Bài toán thực tế. Dịch vụ công điện tử cần xác thực công dân, tổ chức, cán bộ xử lý và văn bản điện tử. Hệ thống cũng cần kiểm tra văn bản đã ký sau khi nó được gửi qua nhiều cổng dịch vụ hoặc lưu trữ lâu dài. Bài toán chính không chỉ là tạo chữ ký, mà là quản lý niềm tin ở quy mô quốc gia.

Cách PKI giải quyết. Trang thông tin chính thức của Trung tâm Chứng thực điện tử quốc gia (NEAC) thể hiện các chức năng liên quan đến CA công cộng, ký số tài liệu, ký số từ xa và kiểm tra văn bản ký số [20]. Ở mức vai trò hệ thống, CA cấp chứng chỉ cho cá nhân, tổ chức hoặc dịch vụ. Người dùng dùng chứng chỉ để ký hồ sơ, văn bản hoặc giao dịch. Dịch vụ công kiểm tra chữ ký và chuỗi chứng chỉ trước khi chấp nhận dữ liệu.

Ký số từ xa chuyển phần kiểm soát khóa sang dịch vụ được vận hành chuyên biệt. Người dùng xác thực với dịch vụ ký, yêu cầu ký tài liệu, rồi nhận chữ ký gắn với chứng chỉ của mình. Mô hình này giảm gánh nặng cài đặt thiết bị ký ở phía người dùng, nhưng đặt yêu cầu cao hơn lên xác thực người dùng, nhật ký ký và bảo vệ hệ thống ký.

Luồng kiểm tra. Một cổng dịch vụ công hoặc hệ thống văn thư nhận tài liệu đã ký. Nó kiểm tra chữ ký trên tài liệu, chứng chỉ người ký, chain đến CA được tin cậy, thời điểm ký và trạng thái thu hồi. Trang NEAC cũng thể hiện chức năng kiểm tra văn bản PDF/XML, kèm thông tin hiệu lực chứng chỉ, chữ ký, timestamp, OCSP và CRL [20]. Những trường này phản ánh các thành phần mà verifier cần khi đánh giá văn bản ký số.

Lỗi và rủi ro triển khai. Rủi ro chính là tính liên thông. Các hệ thống khác nhau phải hiểu đúng định dạng chữ ký, chính sách chứng chỉ, timestamp và trạng thái thu hồi. Nếu verifier chỉ kiểm tra chữ ký mà bỏ qua chain hoặc thu hồi, hệ thống có thể chấp nhận chữ ký từ chứng chỉ không còn hợp lệ. Nếu quy trình ký từ xa xác thực người dùng yếu, chữ ký hợp lệ về mặt mật mã vẫn có thể không phản ánh đúng ý chí của chủ thể.

Chapter 6

Các hệ thống PKI mã nguồn mở

6.1 OpenSSL

Tổng quan OpenSSL

Xây dựng CA đơn giản với OpenSSL

6.2 EJBCA

6.3 Let's Encrypt và Certbot

Let's Encrypt và sứ mệnh

ACME Protocol và Certbot

6.4 Các công cụ và nền tảng khác

XCA

HashiCorp Vault PKI Secrets Engine

CFSSL (Cloudflare)

Dogtag / FreeIPA (Red Hat)

Chapter 7

Thách thức và xu hướng

7.1 Thách thức hiện tại

CA Compromise — bài học từ DigiNotar và Symantec

Certificate Transparency (CT) như giải pháp giám sát

Quản lý vòng đời chứng chỉ

PKI cho IoT

7.2 Xu hướng mới

Post-Quantum PKI

Tự động hoá và rút ngắn thời hạn chứng chỉ

Decentralized Identity (DID)

Chapter 8

Kết luận

8.1 Tổng kết

8.2 Ý nghĩa và triển vọng

Tài liệu tham khảo

- [1] P. R. Zimmermann, *PGP: Source code and internals*, 1995.
- [2] CA/Browser Forum, *Baseline requirements for the issuance and management of publicly-trusted certificates*, 2023. [Online]. Available: <https://cabforum.org/baseline-requirements-documents/>
- [3] D. Cooper, S. Santesson, S. Farrell, S. Boeyen, R. Housley, and W. Polk, “Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile,” IETF, RFC 5280, 2008. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc5280>
- [4] S. Santesson, M. Myers, R. Ankney, A. Malpani, S. Galperin, and C. Adams, “X.509 Internet Public Key Infrastructure Online Certificate Status Protocol – OCSP,” IETF, RFC 6960, 2013. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc6960>
- [5] D. E. 3rd, “Transport Layer Security (TLS) Extensions: Extension Definitions,” IETF, RFC 6066, 2011, Section 8: Certificate Status Request (OCSP Stapling). [Online]. Available: <https://www.rfc-editor.org/rfc/rfc6066>
- [6] P. Saint-Andre and J. Hodges, “Representation and Verification of Domain-Based Application Service Identity within Internet Public Key Infrastructure Using X.509 Certificates in the Context of Transport Layer Security (TLS),” IETF, RFC 6125, 2011. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc6125>
- [7] M. Nystrom and B. Kaliski, “PKCS #10: Certification Request Syntax Specification Version 1.7,” IETF, RFC 2986, 2000. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc2986>
- [8] CA/Browser Forum, *Guidelines for the issuance and management of extended validation certificates*, 2023. [Online]. Available: <https://cabforum.org/extended-validation/>
- [9] J. Schaad, B. Ramsdell, and S. Turner, “Secure/Multipurpose Internet Mail Extensions (S/MIME) Version 4.0 Message Specification,” IETF, RFC 8551, 2019. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc8551>
- [10] R. Housley, “Cryptographic Message Syntax (CMS),” IETF, RFC 5652, 2009. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc5652>

- [11] K. Moriarty, M. Nystrom, S. Parkinson, A. Rusch, and M. Scott, “PKCS #12: Personal Information Exchange Syntax v1.1,” IETF, RFC 7292, 2014. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc7292>
- [12] B. Laurie, A. Langley, and E. Kasper, “Certificate Transparency,” IETF, RFC 6962, 2013. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc6962>
- [13] B. Laurie, A. Langley, E. Kasper, E. Messeri, and R. Stradling, “Certificate Transparency Version 2.0,” IETF, RFC 9162, 2021. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc9162>
- [14] E. Rescorla, “The Transport Layer Security (TLS) Protocol Version 1.3,” IETF, RFC 8446, 2018. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc8446>
- [15] R. Barnes, J. Hoffman-Andrews, D. McCarney, and J. Kasten, “Automatic Certificate Management Environment (ACME),” IETF, RFC 8555, 2019. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc8555>
- [16] C. Adams, P. Cain, D. Pinkas, and R. Zuccherato, “Internet X.509 Public Key Infrastructure Time-Stamp Protocol (TSP),” IETF, RFC 3161, 2001. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc3161>
- [17] C. Kaufman, P. Hoffman, Y. Nir, P. Eronen, and T. Kivinen, “Internet Key Exchange Protocol Version 2 (IKEv2),” IETF, RFC 7296, 2014. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc7296>
- [18] Microsoft, *Cryptography tools – win32 apps*, 2025. [Online]. Available: <https://learn.microsoft.com/en-us/windows/win32/seccrypto/cryptography-tools>
- [19] Apple Developer Documentation, *Code signing services*, 2026. [Online]. Available: <https://developer.apple.com/documentation/security/code-signing-services>
- [20] Trung tâm Chứng thực điện tử quốc gia, *Trang thông tin điện tử trung tâm chứng thực điện tử quốc gia*, 2026. [Online]. Available: <https://neac.gov.vn>